PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Analyse de risques DRSD/DPID

03-570 DRSD - Guide pratique d'analyse de risques — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le niveau de criticité est calculé par la formule probabilité multipliée par la gravité au carré.
2. Le risque brut ignore les mesures existantes tandis que le risque net les intègre via un coefficient compris entre 0,2 et 1.
3. L'analyse de risques est une étape nécessaire mais non suffisante pour obtenir un ATAP.

Objet et concept VUCA

Notion	À retenir
Guide conjoint	Publié en **septembre 2023** par la **DPID** et la **DRSD** ; destiné aux organisations du **ministère des Armées** et entreprises de l'**industrie de défense**.
Concept VUCA	Développé par l'**US Army War College** en **1991** : **V**olatility, **U**ncertainty, **C**omplexity, **A**mbiguity. Regain d'intérêt depuis **2020**.

Cadre méthodologique

Notion	À retenir
Les deux parties	Partie 1 : démarche **tous risques** (toutes menaces/aléas) ; Partie 2 : risque **malveillance** (secret défense, dossier **ATAP**).
Normes et références	Cadre : **ISO 31000** ; Techniques : **ISO 31010** ; Sécurité info : **ISO/IEC 27000**. Référence homologation : `EBIOS Risk Manager`.
Processus de management	4 phases itératives : **appréciation**, **évaluation**, **maîtrise/traitement**, **surveillance/contrôle/réexamen**. Cotation : **gravité au carré** (l'impact prévaut).

Appréciation des valeurs et de l'environnement

Notion	À retenir
Analyse environnement	Contexte **interne** (structure, activités, ressources, sûreté/sécurité) et **externe** (politique, économique, social, malveillances, contrats, naturel/industriel). Aide à la **probabilité**.
Identification valeurs	Inventaire : **RH**, **intellectuel**, **SI**, **image**, **infrastructures**, **prestations externes**, **matériels/capacités**, **transport**. **Attractivité** de chaque valeur pour un malveillant cotée de **1** (non attractive) à **4** (très attractive).

Évaluation des risques

Notion	À retenir
Étape 3	Croisement des valeurs avec le **catalogue ministériel** (menaces/aléas) via un tableau de croisement pour créer des scénarios.
Étape 4	Probabilité (**P1** à **P5**) et gravité (**G1** à **G5**) : impacts humains, opérationnels, financiers, juridiques, environnementaux ou image.
Étape 5	Criticité brute : `probabilité × gravité²` (valeur **1 à 125**), avant prise en compte des mesures ; le risque brut est **significatif** s'il dépasse le seuil d'acceptabilité.
Étape 6	Identification des vulnérabilités (**matériel**, **logiciel**, **réseau**, **personnel**, **organisme/partenaires**, **infrastructure**) et recensement des mesures existantes.
Étape 7	Criticité net : `criticité brut * coefficient`. Coefficients : **1** (absentes), **0,8** (partielles), **0,6** (substitution), **0,4** (performantes), **0,2** (excellentes).
Étape 8	Seuil d'acceptation : fixé par le **propriétaire du risque** selon politiques, objectifs et intérêts. Réévaluation si modification majeure du contexte.

Hiérarchisation et traitement des risques

Notion	À retenir
Étape 9	Hiérarchisation par **criticité nette** et **seuil d'acceptation** : risques **significatifs confirmés** (au-dessus du seuil) ou **significatifs maîtrisés** (en dessous).
Étape 10	Stratégies : **accepter** (risques maîtrisés faible criticité), **éliminer** (risques confirmés criticité élevée) ou **diminuer** (mesures préventives/protection).
Étape 11	Surveillance via **directives nationales**, **instructions ministérielles** et revue des **événements/incidents**. Maintien par **formations**, **entraînements**, **exercices**, **RETEX** et **indicateurs de performance**.

Analyse du risque sûreté (ATAP)

Notion	À retenir
Logique d'effets	Nouvelle réglementation : analyse didactique pour définir au cas par cas les moyens de prévention et protection (ex-obligation de moyens via **IGI 1300**).
Recevabilité	La DRSD évalue **6 critères** : périmètre, méthodologie, identification, cartographie, mesures (prévention/protection) et évaluation (risques à traiter/résiduels).
Étude menace	Dangerosité = croisement **ressources** et **motivation** (échelle **1 à 9**). Objectifs : espionnage, influence, entrave, lucratif, défi, pré-positionnement.
Évaluation sûreté	Utilise la **matrice de PROUTY** (favorise la **gravité** si statistiques de probabilité manquantes). Évaluation sur **5 niveaux** (de **critique** à **très satisfaisant**).

Pièges et confusions

- ⚠ Confondre la gravité avec la probabilité (l'impact prévaut dans le calcul)
- ⚠ Croire que le risque brut prend en compte les mesures de maîtrise
- ⚠ Penser qu'une vulnérabilité peut causer un dommage sans menace pour l'exploiter
- ⚠ Utiliser cette méthode à la place d'EBIOS Risk Manager pour homologuer un système numérique (sauf cas particuliers, comme un système de systèmes exposé à des menaces physiques et numériques).
- ⚠ Oublier de réévaluer les critères d'acceptation lors d'un changement majeur de contexte

Sigles et définitions

VUCA Acronyme de Volatility, Uncertainty, Complexity, Ambiguity (volatilité, incertitude, complexité et ambiguïté)

Risque Probabilité de survenance d'un événement dommageable résultant de la probabilité de l'événement et de sa gravité

Menace Manifestation signifiant une intention hostile, le projet de nuire

Aléa Manifestation d'un phénomène naturel ou anthropique qui exclut toute intention malveillante

Valeur Bien, personne, information ou savoir-faire précieux et vulnérable pour un organisme

Cible Valeur qui représente une attractivité pour un auteur de malveillance

DICT Quatre critères de protection des ISC : disponibilité, intégrité, confidentialité et traçabilité

ATAP Avis technique d'aptitude physique évaluant la cohérence entre l'analyse de risques et les moyens de protection

Auto-test

1. Quelle est la formule de calcul de la criticité ?
2. Quelle est l'échelle de l'attractivité d'une valeur ?
3. Comment appelle-t-on le risque dont la criticité est évaluée avant la prise en compte des moyens de maîtrise ?
4. Quels sont les deux types de mesures pour diminuer un risque ?
5. Qu'est-ce qu'un risque significatif confirmé ?

Réponses : **1.** Probabilité multipliée par la gravité au carré · **2.** De 1 à 4 · **3.** Le risque brut · **4.** Mesures de prévention et mesures de protection · **5.** Un risque net situé au-dessus du seuil d'acceptabilité

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.